# Data Residency

*keep each tenant's data inside its jurisdiction*

Watch the 4-min video

**In one line:** run a complete **regional stamp** of the data plane in each jurisdiction, give every tenant a **home region** in a small global directory, route its requests there, and hunt down every side channel (logs, backups, support tools, analytics, third parties) that would copy its data across the border.

## 1 The clause that stops the deal

A German bank is ready to sign, but one clause blocks it: *all of our customer data must stay in the European Union*. Your platform runs in one US region with backups in another US region. To win the deal you need data residency, and it is far easier to design in early than to retrofit.

## 2 Residency, sovereignty, localisation

| Term | Means | Typical driver |
|---|---|---|
| Data residency | data is stored (and often processed) only in named regions | customer contracts, GDPR transfer rules |
| Data sovereignty | data is subject only to that jurisdiction's laws, including who operates it and who can be compelled to hand it over | public sector, banks; concern about foreign laws such as the US CLOUD Act |
| Data localisation | a law requires certain data to stay in the country | e.g. the Reserve Bank of India's 2018 rule that payment system data be stored only in India |

GDPR itself does not say "store data in the EU". It restricts **transfers** of personal data outside the EEA (Chapter V) unless the destination has an adequacy decision (for example the 2023 EU-US Data Privacy Framework for certified US companies) or safeguards such as standard contractual clauses (SCCs) are in place. The 2020 *Schrems II* ruling, which struck down the earlier Privacy Shield, made many EU customers prefer simply keeping data in the EU, which is why residency shows up in contracts. Sovereignty goes further and may require EU-resident operators and EU-controlled keys; cloud providers now sell "sovereign cloud" offerings for this.

## 3 Regional stamps and home regions

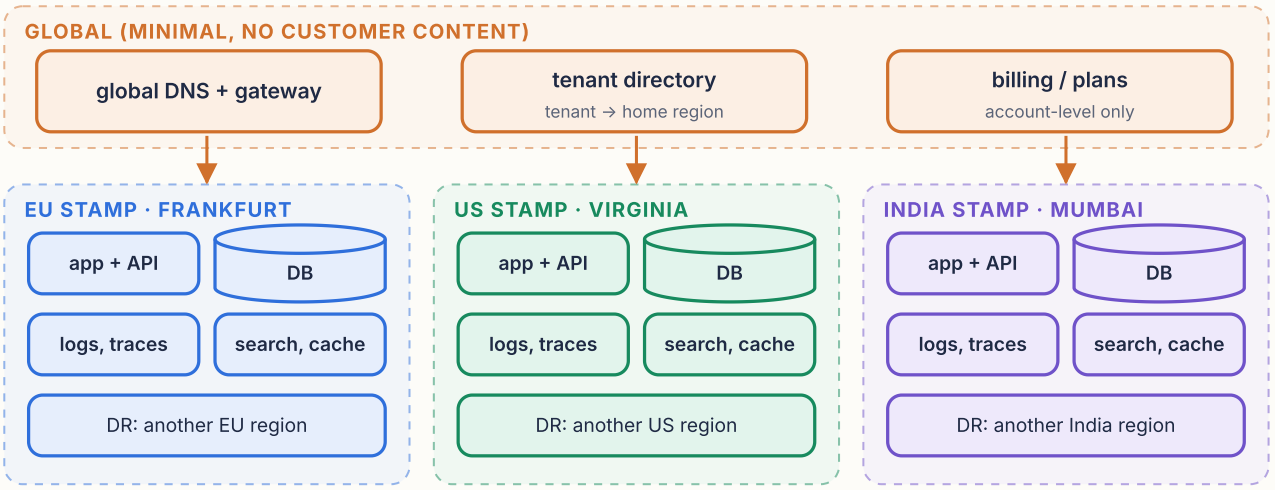



**Figure 1.** Each region runs a full copy of the data plane, including its own logs, search and backups. The global layer holds only routing and account data.

Instead of one global deployment, run a complete copy of the data plane per region: an **EU stamp** in Frankfurt, a US stamp in Virginia, an India stamp in Mumbai, each with its own databases, object storage, search, caches, queues, logs and backups (deployment stamps, lesson 50). Every tenant gets a **home region** at sign-up, recorded in a global tenant directory. A global routing layer (DNS plus an API gateway or front door) looks up the tenant and forwards the request; a German bank employee travelling in New York is still served from Frankfurt. Regional hostnames such as `bank.eu.app.com` make routing trivial and the location visible.

Login is the subtle part: to find a user's tenant from their email address, a global index of emails would itself be personal data stored globally. Common answers: route by tenant subdomain or a region picker before login, or keep only a keyed hash of the email domain in the global directory and resolve the user inside the home region.

## 4 Accidental leaks: the hard part

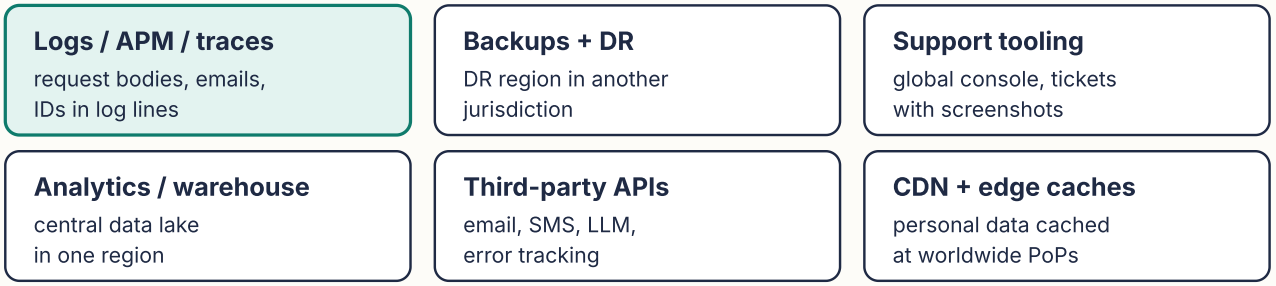



**Figure 2.** Where residency usually breaks. Each one needs a regional answer or scrubbing.

- **Observability.** Logs, traces and error reports contain emails, IDs and sometimes request bodies. Keep the pipeline regional (a regional Elasticsearch or the vendor's EU site), or scrub personal data before anything leaves the region.
- **Backups and DR.** Replicate to a second region **inside** the jurisdiction: Frankfurt to Paris or to Germany North, never to a US region. Check the provider's default backup geo-redundancy setting, which may pick a paired region for you.
- **Support.** An EU-hosted support console; tickets and screenshots in a regional helpdesk instance; access by approved staff (break-glass, lesson 43).

- **Analytics.** No central data lake of raw customer data: aggregate or anonymise in-region and export only non-personal results.
- **Third parties.** Email and SMS providers, error trackers and LLM APIs are sub-processors; choose EU endpoints or EU data-processing options and list them in your data processing agreement.
- **Edge.** A CDN caching personalised responses stores them at points of presence worldwide; mark them uncacheable or restrict the edge locations.

## 5 Keep global data minimal

Some data is genuinely global: the tenant directory, billing accounts, plan definitions, product configuration. Keep it small, use opaque IDs, keep personal data out of it, and document every cross-border flow in a data map. When a transfer is unavoidable, use the legal mechanisms (SCCs plus a transfer impact assessment) and technical ones: encrypt with keys held in the customer's region, ideally customer-managed (BYOK) in an in-region key vault or HSM, so data that crosses a border is useless without a key that never does.

**WORKED EXAMPLE: EU CUSTOMERS' DATA ONLY IN EU REGIONS**

The company deploys an EU stamp with a primary in Frankfurt and disaster recovery in Paris. The tenant directory records `german-bank → EU`. Global DNS and the API gateway route `german-bank.eu.app.com` to the EU stamp. Logs and traces go to an EU-hosted observability stack; support engineers use the EU support console; transactional email goes through the provider's EU region; the database is encrypted with the bank's own key in an EU key vault; backups replicate Frankfurt → Paris and never leave the EU. The contract's annex lists every sub-processor and its location.

**TRADE-OFFS**

- Every region you add is another full stack to run, patch, monitor and pay for.
- Cross-region features (global search, shared workspaces between an EU and a US tenant) become hard or impossible.
- DR inside one jurisdiction may mean regions that are closer together than you'd otherwise pick.
- Central analytics and ML on raw customer data must be redesigned around in-region processing.

**COMMON MISTAKES**

- Moving the database to the EU but shipping logs and traces to a US observability tenant.
- Default geo-redundant backups replicating outside the jurisdiction.
- A global user table of emails used for login routing.
- Forgetting sub-processors: email, error tracking, AI APIs.

## 6 Key terms

**Data residency**: data stored and processed only in named regions

**Home region**: the region a tenant's data lives in

**SCCs**: standard contractual clauses for GDPR transfers

**Sovereignty**: data subject only to one jurisdiction's laws

**Tenant directory**: global map of tenant → home region

**Sub-processor**: third party that processes customer data for you

## 7 Interview questions

**Q1. How do you meet data residency requirements in a global SaaS?** BASIC

Deploy regional stamps with all customer data inside each region, assign every tenant a home region in a global directory, route requests there, and keep logs, backups, support tools and third-party processing regional too.

**Q2. What's the hardest part?** BASIC

Accidental cross-border leaks through logs, analytics, backups, support tooling and external services.

**Q3. Residency vs sovereignty?** BASIC

Residency is about where data is stored and processed; sovereignty is about which jurisdiction's laws apply, including who operates the system and who can be compelled to access it.

**Q4. An EU user logs in from the US. Where is the request served?** SCENARIO

From the EU stamp: routing is by the tenant's home region in the directory, not by the user's location.

**Q5. How do you do disaster recovery for an EU-only tenant?** SCENARIO

Replicate to a second region within the EU (e.g. Frankfurt to Paris) and verify the provider's default backup redundancy doesn't pick a region outside it.

**Q6. Does GDPR require data to be stored in the EU?** TRICKY

No; it restricts transfers outside the EEA unless there's adequacy or safeguards like SCCs, but many customers contractually require EU storage to avoid transfer risk.

**Q7. How do users log in if you can't keep a global email index?** TRICKY

Route by tenant subdomain or regional URL, or a region picker, or keep only a hash of the email domain globally and resolve the user inside the home region.

Next: SD-R-007 · Enterprise SSO backendroadmap.com